

Phishing Incident Analysis Report

Case ID: PG-F8590FCF
Generated: 2026-09-13T12:42:48.386Z

Overall Severity: 16/100 (Medium)
CVSS 3.1 Base Score: 6.9
CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:L/A:N



1. Executive Summary

This report documents the analysis of a phishing email purportedly from "it@example.com". Of 1 employee(s) assessed, 100% took a compromising action (credential entry and/or attachment execution). Overall composite severity is scored 16/100, corresponding to a CVSS 3.1 base score of 6.9.

2. Email Header & Authentication Analysis

Identity:

From: it@example.com
Reply-To: N/A
Return-Path: N/A
Subject: urgent verify

Authentication Results:

SPF: none | DKIM: none | DMARC: none

Findings:

[LOW] No SPF record evaluation found in headers — could not verify sender authorization.

[LOW] No DKIM signature present — message authenticity cannot be cryptographically verified.

[HIGH] No Received: headers found. This is unusual for legitimate mail and may indicate a forged or manually crafted header block.

Header Risk Score: 12/100

3. Malicious Link & QR Code Analysis

1. <https://example.com/login>

Verdict: LIKELY_BENIGN | Score: 0/100

No findings in this category.

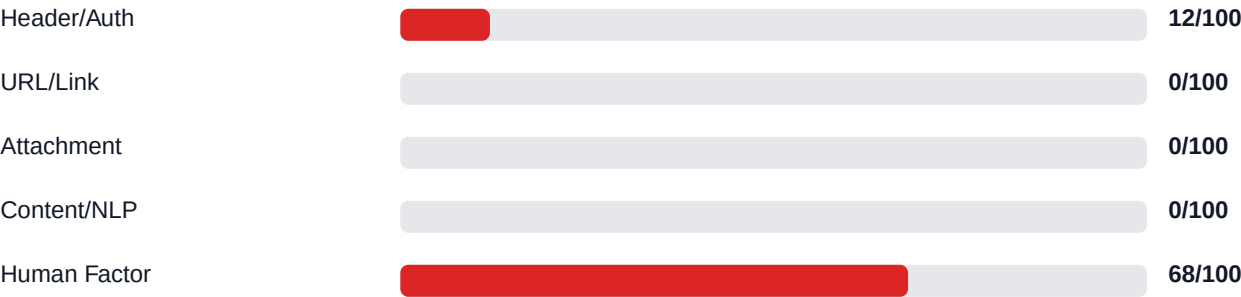
4. Attachment Analysis (Metadata, Stego Screen, Hash Reputation)

5. Content & NLP / Persuasion-Tactic Analysis

Detected tactics (mapped to Cialdini's principles of influence):

Content Risk Score: 0/100

6. Composite Severity Breakdown



CVSS 3.1
Vector:
CVSS:3.1/AV:N/
AC:H/PR:N/UI:R/
S:C/C:H/I:L/A:N
CVSS Base
Score: 6.9
(Medium)

7. Standards Mapping — OWASP Top 10 & MITRE ATT&CK

OWASP Top 10 (2021) Relevance:

A01:2021 — Broken Access Control

If harvested credentials grant the attacker unauthorized access to systems the victim was authorized to use.

A03:2021 — Injection

Relevant if the phishing payload leads to script/macro injection via the attachment.

A05:2021 — Security Misconfiguration

Relevant where SPF/DKIM/DMARC were absent or misconfigured, enabling spoofing.

A07:2021 — Identification and Authentication Failures

Directly relevant when credentials were harvested and MFA was absent or bypassed.

A09:2021 — Security Logging and Monitoring Failures

Relevant if the phishing email or resulting compromise was not detected by existing monitoring.

MITRE ATT&CK Techniques Observed:

T1566 — Phishing (Tactic: Initial Access)

T1566.001 — Spearphishing Attachment (Tactic: Initial Access)

T1566.002 — Spearphishing Link (Tactic: Initial Access)

T1598 — Phishing for Information (Tactic: Reconnaissance)

T1204 — User Execution (Tactic: Execution)

T1656 — Impersonation (Tactic: Resource Development / Defense Evasion)

8. Forensic & Psychological Analysis (Per-Employee)

Note: This section identifies which social-engineering mechanisms the questionnaire responses indicate were effective. It is a behavioral/pattern analysis for security-training purposes, not a clinical or diagnostic assessment of any individual.

emp001



68/100

Employee:
emp001 | Dept:
Finance | Tier:
High Susceptibility
[CRITICAL] Employee entered credentials on the phishing page — direct account compromise risk.
[MEDIUM] Employee acted on an email they were not expecting, without independent verification through a second channel.
[MEDIUM] No prior completed security awareness training on record for this employee — a contributing organizational (not individual) factor.
[HIGH] Employee did not report the incident to security, delaying containment and increasing organizational dwell-time risk.
Recommended follow-up:
- Immediate password reset + force re-authentication with MFA enrollment check.
- Enroll in targeted phishing-simulation micro-training within 2 weeks.
- Complete baseline security awareness training module.
- Coach on the 'report first, don't investigate yourself' reporting policy.

Organization-Level Psychological Summary:
Average human-factor score: 68/100
Click-through /

compromise rate:
100%
High-susceptibility
employees: 1

9. Mitigation & Security Recommendations

Technical Measures:

[CRITICAL] Publish/enforce a DMARC policy at p=reject (after a monitoring period at p=quarantine) to stop spoofed mail using your domain. (Ref: RFC 7489)

[CRITICAL] Mandate phishing-resistant MFA (FIDO2/WebAuthn) for all accounts, especially those confirmed to have entered credentials. (Ref: NIST SP 800-63B / OWASP A07:2021)

[HIGH] Enforce SPF with a hard-fail policy (-all) on all sending domains. (Ref: RFC 7208 / NIST SP 800-177)

[HIGH] Deploy/repair DKIM signing on outbound mail infrastructure and rotate keys periodically. (Ref: RFC 6376)

[MEDIUM] Ensure EDR/antivirus coverage on all endpoints with real-time behavioral detection, not signature-only. (Ref: CIS Control 10)

Policy Measures:

[HIGH] Enforce immediate password rotation + session revocation for any account confirmed to have disclosed credentials.

[HIGH] Establish/reinforce a one-click 'Report Phishing' button in the mail client tied to the SOC triage queue.

[HIGH] Introduce a no-blame reporting culture policy to reduce delayed/non-reporting behavior observed in this incident.

[MEDIUM] Implement out-of-band verification requirement for any request involving credentials, payments, or urgent account actions.

Training Measures:

[HIGH] Enroll the 1 identified high-susceptibility employee(s) in focused 1:1 coaching + follow-up simulated phishing test within 30 days.

[LOW] Run quarterly organization-wide phishing simulations with escalating sophistication, tracked against this incident's baseline click-through rate.

10. Chain of Custody — Artifact Hashes (SHA256)

Raw email source

SHA256: 1ffde1e4d84b86bf467f24d3bf180507dd80937022bedda56a3814f9d36472bc

Hashed at: 2026-09-13T12:42:47.671Z